加雲聯網股份有限公司

OT Security Policies and Procedures Plan

版 別：1.0

制訂日期：2024 年 5 月 XX 日

修訂日期：2024 年 5 月 XX 日

制修部門：XXX

頁 數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

CONTENTS

1.0 Purpose 7
1.1 Introduction 7
1.2 Purposes and Objectives 7
2.0 Scope of application 7
3.0 Definitions 8
3.1 Definitions 8
3.2 Abbreviations 8
3.3 Applicable Documents 9
3.3.1 Employer's Requirements 9
3.3.2 Related Documents 9
4.0 Account Management Policy 10
4.1 Account 10
4.1.1 Centralized Accounts 10
4.1.2 Local accounts 10
4.1.3 User Identity Validity 10
4.1.4 Account Naming 10
4.2 Documentation Of Policies and Procedures for Protecting the Assets 12
4.2.1 Rights Principles 12
4.2.2 Authorization Levels 12
4.2.3 Rights Matrix (Roles and Permissions) 12
4.2.4 Exception 13
4.3 Password Policy 13
4.3.1 General user account password policy 13
4.3.2 Local Administrator user account password policy 13
4.3.3 Operational and System Administrator user account password policy 14
5.0 Vulnerability Management procedure 15
5.1 Process steps Description 15
5.1.1 Vulnerability Management Report Map 15
5.1.2 Vulnerability Management Process 15
5.1.3 Security Analysis Tool Evaluation ..... 錯誤! 尚未定義書籤。
5.2 Logical Structure of the vulnerability solution 15
5.2.1 Test Configuration 15
5.2.2 Test Method/Tool 16

5.2.3 Vulnerability handling process .....錯誤! 尚未定義書籤。
6.0 Backup/Restore procedure 18
6.1 Backups 18
6.1.1 Backup of assets and information 18
6.1.2 Backup Supervision 18
6.2 Backup Security 20
6.2.1 Retention and Frequency 20
6.3 Restoration 21
6.3.1 Testing Request 21
6.3.2 Testing Exercise 21
6.4 Disaster Scenarios 21
6.4.1 Windows based host server crash in 21
6.4.2 Malware detected during backup 22
6.4.3 Corrupt configuration file 22
6.5 Recovery Procedures 22
6.5.1 Windows-based host servers Recovery 22
6.5.2 ICS and Network Devices Recovery 24
6.6 Logical setup of the backup infrastructure 25
6.6.1 Windows based host server's backup infrastructure 25
6.6.2 ICS Devices and Network Devices backup infrastructure 25
7.0 Systems Malware Protection procedure 26
7.1 General Rules 26
7.2 Central Management 26
7.2.1 Malware Protection for on-site host computers 26
7.2.2 Malware Protection for computers that temporarily connected to the on-site network or devices 27
7.2.3 Malware Protection for portable medias 28
7.3 UPDATE & PATCH 29
7.3.1 Logical structure of Malware Protection for on-site host computers 29
7.3.2 Logical structure of Malware Protection for computers that temporarily connected to the on-site network or devices 29
7.3.3 Logical structure of Malware Protection for portable medias 30
7.4 Incident Management 30
7.5 Device with no protection mechanisms 30
7.6 Logical structure of Malware protection 31

7.6.1 Logical structure of Malware Protection for on-site host computers 31
8.0 Change and Patch Management procedure 32
8.1 Main Principles of Configuration 32
8.2 Windows based host servers (WBHS) 34
8.2.1 WBHS Configuration Files (tentative) 34
8.2.2 WBHS Configuration Revision Control & Management Table (tentative) 34
8.3 ICS & Network Devices Configuration 35
8.3.1 ICS & Network Devices Configuration Files (tentative) 35
8.3.2 ICS & Network Devices Configuration Revision Control & Management Table (tentative) 36
8.4 Change Management 36
8.5 Patch Management 38
8.5.1 Patch Management Map 38
8.5.2 Patch Management Process 40
9.0 Logging, monitoring, and reporting procedure 41
9.1 Information Logging 41
9.1.1 Overview of information logging policy 41
9.1.2 Purpose of information logging policy 41
9.1.3 Scope of information logging policy 41
9.1.4 Information logging policy standard 41
9.1.5 Information logging policy compliance 42
9.2 Asset Monitoring 42
9.2.1 Overview of asset monitoring policy 42
9.2.2 Purpose of asset monitoring policy 43
9.2.3 Scope of asset monitoring policy 43
9.2.4 Asset monitoring policy standard 43
9.2.5 Asset monitoring policy compliance 43
9.3 Event Management & Reporting 44
9.3.1 Security Log Management Goals 44
9.3.2 Logging General Setup 44
9.3.3 Collected Data Quality 44
9.3.4 Data Security and Integrity 44
9.3.5 Event From the Devices (tentative) 45
9.4 Storing and forwarding of the event 45
9.4.1 Storing process. 45

9.4.2 Access 45

9.4.3 Forwarding 45

9.5 Logical logging Setup..... 46

1.0 Purpose

1.1 Introduction

This document outlines the Operational Technology (OT) security policies and procedures for account management, vulnerability management, backup/restore management, systems malware protection management, change and patch management, and logging, monitoring, and reporting management.

1.2 Purposes and Objectives

The policies and procedures aim to ensure a systematic and secure approach to applying updates, maintaining system integrity, and minimizing vulnerabilities within the OT environment.

2.0 Scope of application

The System under Consideration (SuC) for IEC 62443-2-4 Dummy System, the applicable scope of systems, sub-components for OT Security Management Plan are shown in the following table, which based on the “OT Security Detailed Risk Assessment Report”. The asset list could refer to “Dummy Project - Inventory Asset List”.

The applicable scope of systems, sub-components for this management plan includes:

Location	Asset	Description
03 SCADA Zone	SCADA HMI Server	Graphical monitoring interface
02 Control Zone	IED (Control)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
01 SIS Zone	IED (Protection)	An integrated microprocessor-based controller of power system equipment, such as circuit breakers, transformers and capacitor banks
02 Control Zone	Ethernet Switch (Control)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
01 SIS Zone	Ethernet Switch (Protection)	Connects devices on a computer network by using packet switching to receive and forward data to the destination device
05 Tempory Zone	Wireless AP	A networking hardware device that allows other Wi-Fi devices to connect to a wired network or wireless network

3.0 Definitions

3.1 Definitions

Definition	Description
Asset Owner	Individual or organization responsible for one or more Industrial Automation and Control Systems (IACSs).
Automation Solution	Control system and any complementary hardware and software components that have been installed and configured to operate in an IACS.
Component	One of the parts that make up a product or system.
Dependent Component	Component external to the product on which the product depends.
Integration Service Provider	The service provider provides integration activities for an Automation Solution including design, installation, configuration, testing, commissioning, and handover.
Maintenance Service Provider	The service provider that provides support activities for an Automation Solution after handover.
Product Supplier	Manufacturer of hardware and/or software products.
Recovery Point Objective	Time value that determines the maximum tolerable period of data loss due to a disaster (e.g., data corruption).
Recovery Time Objective	The overall length of time an information system's components or an operating system's components can be in the recovery phase before negatively impacting the organization's mission or mission/business/operating functions.
Service Provider	Individual or organization (internal or external organization, manufacturer, etc.) that provides a specific support service and associated supplies in accordance with an agreement with the asset owner.

3.2 Abbreviations

Abbreviation	Clarification
EPC	Engineering, Procurement and Construction
SAT	Site Acceptance Test
SIT	Site Integration Test
VIT	Vulnerability Identification Testing

3.3 Applicable Documents

3.3.1 Employer's Requirements

No	Employer's DOC No	DOC Title
1		OT Security Requirements for dummy project
2		Master Time Schedule

3.3.2 Related Documents

No	ICP DOC No	Employer's DOC No (if applicabe)	DOC Title
1			OT Security Management Plan
2			OT Security Vendor Management Plan
3			Dummy Project -Data Flow Diagram
4			Dummy Project - Inventory Asset List
5			Dummy - Simple Network Diagram
6			Dummy Project -Initial Risk Assessment
7			Dummy Project -Detail Risk Assessment

4.0 Account Management Policy

The requirements of least privileged use rules and mutual authentication for network devices from the Employer should be considered. This chapter on Account and Privilege Management Policy should incorporate the requirements of the Employer to configure the least privileged use of SuC's network devices. If the Account Management Policy below conflicts with the requirements of the Employer, the requirements of the asset owner will prevail.

The Account Management Policy should be reviewed and approved by Employer.

Access control for network devices, including wireless network devices, should be configured according to the following Account Management Policy

4.1 Account

4.1.1 Centralized Accounts

- For Microsoft-based Host Devices, Microsoft Active Directory (AD) will be used as the catalogue service, as it is already an integrated part of the operating system. This makes it possible to centrally control user permissions, login requirements, and password requirements. Password change management for domain accounts will be controlled by a Group Policy Object (GPO). All service accounts and normal accounts will have their passwords changed manually.
- Access to resources will be controlled by a method called Role-Based Access Control (RBAC). This simplifies user and resource management and permission tracking. The principle of RBAC is to assign permissions to roles rather than directly to users.

4.1.2 Local accounts

- Least privilege based on Role-Based Access Control (RBAC) shall be assigned to each account.
- Data in transit shall be encrypted, by means of the following HTTPS, SSH, SFTP, and SCP protocols, as example.
- Unused accounts shall be removed.
- Password complexity shall match the Employer’s standard and/or requirements.
- For Microsoft-based Host Devices, only one local account is allowed.
- All local accounts and passwords should be reviewed and approved by the Employer.

4.1.3 User Identity Validity

- Suggest that the accounts should be created in AD, but not limited to.
- AD could support temporary accounts, but they should be valid only until the configurable expiry date. In the Project to be decided
- Expired or invalid accounts shall be deleted, immediately.

4.1.4 Account Naming

- It should ensure that there are no hidden accounts nor are there passwords that cannot be changed.

- Unused system default accounts should be removed or disabled, including whether they are installed with the operating system or with the control system or related software, including unnecessary built-in accounts.
- Default admin account should be renamed if applicable. Additionally, default passwords should be changed as required by the PE/O, including after the process of installation, re-installation, and reset/recovery.
- To be finalized in detail refer to 4.2.3 Rights Matrix (Roles and Permissions).

4.2 Documentation Of Policies and Procedures for Protecting the Assets

4.2.1 Rights Principles

- The user rights of policies and procedures are corresponded to the work/task of the account.
- Least privilege of right is assigned to each account, based on RBAC.
- The management of user rights is based on the Group Policy mechanism.

4.2.2 Authorization Levels

Several authorization levels according to the job need to be formed by the Employer. The authorization levels are:

- **Viewer**: The access of the user is limited to read/browse the system/HMI only.
- **Control**: The user is allowed to make control operations, for example, to control switching devices with limited rights.
- **Engineering**: All rights are granted, excluding user management, which can be performed only by the system manager.
- **System manager/ Administrator**: The user with this authority level is the system manager. All rights are granted, including the rights to add and remove users and authorization groups.

4.2.3 Rights Matrix (Roles and Permissions)

List below should be updated and checked in FAT and SAT, for assets in SuC. Policies and Procedures Integration Plan (PPIP) shall include the Rights Matrix with part of Appendix to be as evidence of account management and it adheres to account management policy.

		SCADA system			Safety Control system	Configuration & Auxiliary management system
User role	Security group AD	SCADA HM	IED (Control)	Ethernet Switch	IED (Protection)	Wireless AP (could be connected to a laptop)
Administrator						
SCS Engineer						
Network Engineer						
IT Security						
Operator / Viewer						

Account List Excel sheets for all device user accounts, including system-level accounts, user-level systems, admin-level systems, etc. password complexity, and the

frequency will be provided in the PPIP or O&M-related attachment to management accounts.

4.2.4 Exception

Any Exceptions must be documented, and regularity reviewed, and the document with exception information will be informed ICP by email or through specified system, such as Acronis.

4.3 Password Policy

4.3.1 General user account password policy

- Passwords should consist of minimum three of the following characteristics: UPPERcase, lowercase, number, and special characters, if supported.
- All user-level passwords must be at least 8 characters if the system supports this, and no longer than 32 characters. Otherwise, the longest possible length shall be used.
- Passwords set for first time use and passwords being reset shall be set to a unique value for each user and shall be changed immediately after first time use, if supported.
- Passwords and user IDs shall be communicated separately, preferably by different means of communication (e.g. email, text, call, etc.).
- All user-level passwords (e.g., email, web, desktop computer, etc.) must be changed when there’s reason to believe a password has been compromised but at least every 90 days, if supported.
- Password renewals: a new password is required for the first 24 expiries; thereafter the first password can be reused. A new password is recommended each time it is required if supported.
- 5 login fail trials are allowed, and then the account will be locked for a period or re-apply for unlocking before it can continue to be used if supported.
- For unsupported above requirements, it should be changed the default password, and the length of the password should be set to the maximum length that the device provided and should be changed manually yearly.

4.3.2 Local Administrator user account password policy

- The password must be composed using at least 3 of the following characteristics: UPPERcase, lowercase, numbers, and special characters if the system supports this. Otherwise, the highest complexity shall be used and must be documented as a deviation.
- All local-system-level passwords must be at least 12 characters if the system supports this. Otherwise, the longest possible length shall be used and must be documented as a deviation.
- Admin-level accounts shall have 16-character passwords if supported.
- Service accounts (used for robots etc.) shall have 36-character passwords, if supported.

- Passwords set for first-time use and passwords being reset must be set to a unique value for each user (use of standard passwords is NOT allowed) and must be changed immediately after the first use.
- Passwords and user IDs shall be communicated separately, preferably by different means of communication (e.g. email, text, call, etc.).
- All user-level passwords must be at least 12 characters if the system supports this. Otherwise, the longest possible length shall be used and must be documented as a deviation.
- If a user requests a password reset then before performing a password reset, the user identity must be verified and documented.
- Do not use the same password for Asset Owner accounts as for other non- Asset Owner access (e.g., personal, ISP (Internet Service Providers) account, online web-shop, banking login etc.).
- Reuse of old passwords are not allowed.
- Passwords should be reset at least annually.
- Multiple unsuccessful logins, such as 3 times, within defined time periods shall be detectable where possible and flagged for further analysis. Further, the account shall be locked in a period or re-apply for unlocking before it can continue to be used, if supported.
- Multifactor authentication should be configured as a minimum on the edge of the OT environment.
- For unsupported above requirements, it should be changed to the default password, and the length of the password should be set to the maximum length that the device provided and should be changed manually yearly.

4.3.3 Operational and System Administrator user account password policy

- All non-privileged accounts to maintain Scheduler/Cronjob, application to DB connection, Windows Service passwords must be at least 16 characters if the system supports this, and no longer than 64 characters. Otherwise, the longest possible length shall be used. The password expiry value may then be set as “Never Expires”.
- System-level accounts shall have 18-character passwords, if supported
- All domain-administrator-level/DB Administrator/Cloud Administrator/Device Administrator passwords must be at least 24 characters if the system supports this, and no longer than 64 characters. The password expiry value may be set up to 360 days. User accounts that have system-level privileges and programs like “sudo” must use multi-factor authentication if the system supports this.
- The password must be composed using at least 3 of the following characteristics: UPPERcase, lowercase, numbers, and special characters.
- Admin-level accounts shall renew passwords minimum every 180 days.
- Service accounts (used for robots, data extraction engines etc.) shall renew passwords minimum every 360 days.
- For unsupported above requirements, it should be changed to the default password, and the length of the password should be set to the maximum length that the device provided and should be changed manually yearly.

5.0 Vulnerability Management procedure

5.1 Process steps Description

5.1.1 Vulnerability Management Report Map

A vulnerability reported to the contractor (a) directly by OT-security Consultant Team (ICP), (b) directly by Subcontractor/SI, (c) directly by Suppliers.

5.1.2 Vulnerability Management Process

The vulnerability scan scope would include all IP-based assets in SuC that connect to the Systems and Networks. The vulnerability scan testing will be performed in the following 3 stages:

1. At the post (or end of) FAT, the OT-security Consultant Team should support Product Suppliers or Subcontractors to perform the vulnerability scan for all IP-based assets in SuC and provide the vulnerability scan report.
2. At the end of the SAT, the OT-security Consultant Team should support support Product Suppliers, Subcontractors, and/or SI perform the vulnerability scan for all IP-based assets in SuC and provide the vulnerability scan report.
3. At the end of the SAT, the OT-security Consultant Team should perform the Threat Mitigation Testing, to verify the measures or countermeasures implemented to mitigate the threat and test the resilience of these implemented measures or countermeasures.
4. During the SAT and SIT, the OT-security Consultant Team should perform the Penetration Testing, to determine how intrusion testers simulate real-world attacks to circumvent a system or cybersecurity function. Penetration testing is designed to demonstrate the resilience of IACS' SuC to identified threats and risks. The penetration testing at the SIT will be carried out together under the Employer’s guidance.

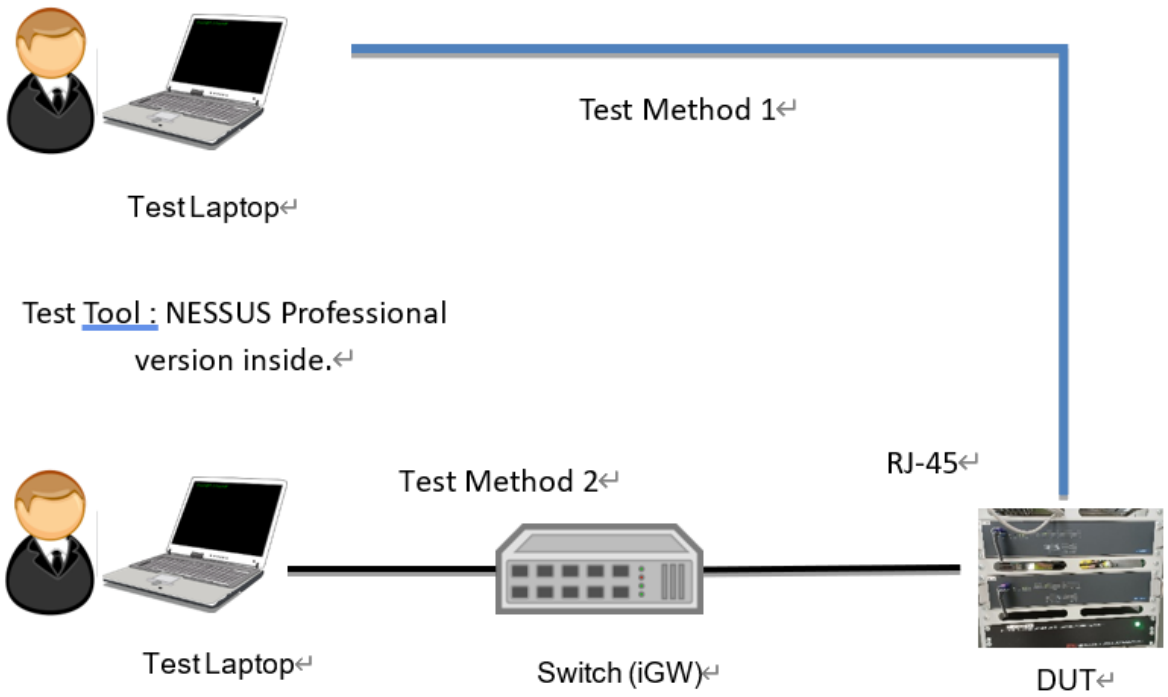
Note: After handover to Asset Owner, the period of vulnerability scans will be decided by the service level agreement (SLA). It is recommended to perform a passive vulnerability scan on each asset annually.

5.2 Logical Structure of the vulnerability solution

The technical steps/procedure/screenshots to run the vulnerability scan tests should be described in PPIP. The test also shall be performed under running mode of Automation Solution, to test the ability to maintain operation of essential control system functions in the presence of system and/or network scans during normal operation. The successful of vulnerability scan test is that it should not cause any effect of operation of Automation Solution like interrupt, delay, etc.

5.2.1 Test Configuration

The Test Configuration was as shown below, including 2 test methods:



5.2.2 Test Method/Tool

- **Requirements for the Use of External System/Equipment/Tool**

After the SAT or the systems are handed over to Asset Owner, three requirements for the use of external systems/equipment/tools for Vulnerability Test should be followed:

- All handling of Asset Owner's information must be done in accordance with the secure behaviour policy. Specifically, section 1 (regarding classification and handling of information) and section 2 (regarding the use of software and devices).
- All external systems/equipment/tools that store or process Asset Owner's information must pass through an evaluation and approval process before they can be used to store, process, or transmit Asset Owner's information.
- Only approved external systems/equipment/tools may be used to store, process, and transmit Asset Owner's information.
- **Test Method 1**

The Test Laptop connected to the DUT (device under test) directly with an RJ-45 port of DUT (temporarily unplugged and replaced the RJ-45 port connection of DUT which connected to a TECH network's switch). The Test Laptop could use a VM that installed Nessus Vulnerability Assessment tools inside to test. This type of asset would be tested by connecting to the asset's network port (temporarily unplugging the asset's

original network cable). The Vulnerability test of the test Laptop's sweep address scope was limited to the DUT's IP only.

- **Test Method 2**

The Test Laptop connected to a local switch or gateway (temporarily unplugged and replaced the RJ-45 port connection of the switch/gateway which connected to the Engineer server). The DUTs also connect to the switch/gateway by RJ-45 port. The Test Laptop used a VM that installed Nessus Vulnerability Assessment tools inside to test. The Vulnerability test of the test Laptop's sweep address scope was limited to the DUTs' IP only. In general, these types of assets were connected to a local gateway and then connected to the Asset Owner's network switch or servers. The Engineer server was connected to specified gateway and then connected to all RTUs, for this type of testing, the Test Laptop network cable was used to replace the Engineer server's network cable and then connected to specified gateway switch to test.

- **Threat Mitigation Testing Method/Tool**

The testing or analyzing tools could include Nmap, metaexploit, wireshark, sqlcmd, OWASP ZAP, burpsuite, Hydra, and Reaver. The selection of testing tools would depend on the security requirements and function items of detailed risk assessment results.

- **Vulnerability Testing Method/Tool**

The testing or analyzing tools could include CIS-CAT Pro v4, Kali, Burp Suite, hashcat, Nmap, metaexploit, wireshark, sqlcmd, OWASP ZAP, burpsuite, Hydra, and Reaver. The selection of testing tools would depend on the attack paths and threat vectors of detail risk assessment results, to find the unanalyzed weaknesses in SuC.

6.0 Backup/Restore procedure

6.1 Backups

6.1.1 Backup of assets and information

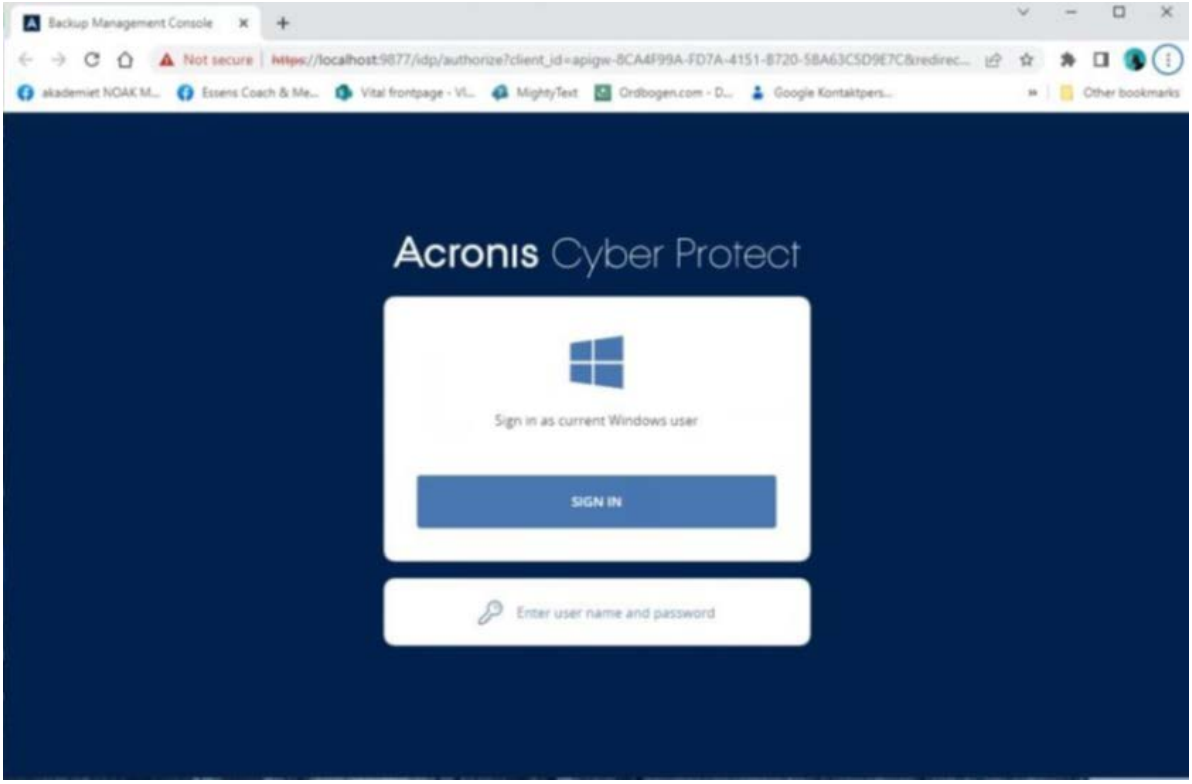
The backup target will be decided after detailed risk assessment. In general, it will include 3 types of assets to perform the backup procedures, include:

1. Windows based or Linux host servers: SCADA HMI Server
2. ICS Devices: IED (Control) and IED (Protection)
3. Network Devices: Ethernet Switch (Control), Ethernet Switch (Protection) and Wireless AP

6.1.2 Backup Supervision

- **Windows based host servers**

During the post of FAT or the SAT, the Acronis Agent will be installed on the Windows-based server. The agent is configured with the IP address of the Acronis backup station. Once started the agent will communicate with the Acronis backup station in the Park DMZ from where its operation will be controlled. Backup schedules will be configured centrally from the Employer’s IT, following the Employer’s backup policies. PPIP shall provide detailed steps/procedure/screenshots for backup & restore for individual assets.



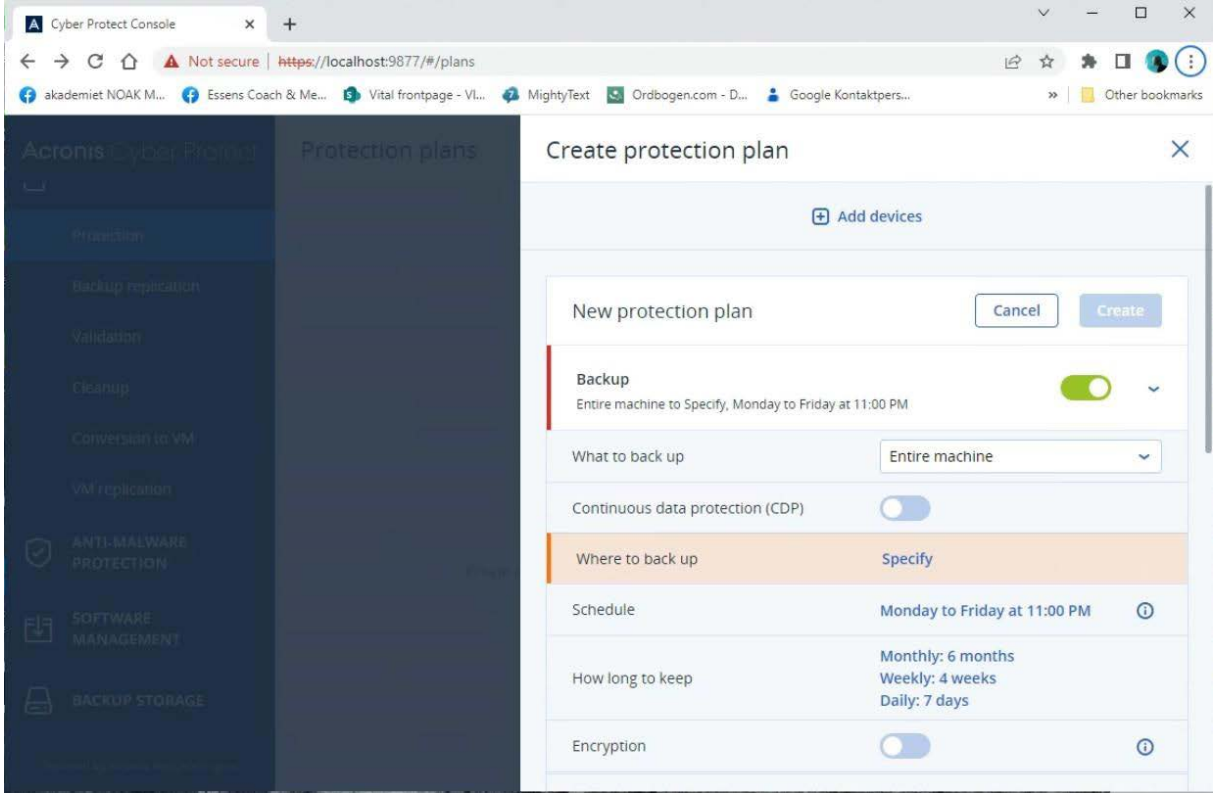


Figure 6-1 Set “Where to back up”

- **ICS Devices**
  - The configuration files of the ICS devices should be copied to an on-site windows-based file server yearly. The windows-based file server should perform the backup procedure.
  - Once the configuration of the firewalls and network devices have been changed, the new version of the configuration files should be copied to an on-site windows-based file server immediately with a different file name, then the windows-based file server will be regularly backed up to the Employer’s servers.
- **Network Devices**
  - The configuration files of the firewalls and network devices should be copied to an on-site windows-based file server yearly. The windows-based file server should follow the 3.2.1 procedure to perform the backup procedure.
  - Once the configuration of the firewalls and network devices have been changed, the new version of the configuration files should be copied to an on-site windows-based file server immediately with a different file name, then the windows-based file server will be regularly backed up to Employer’s servers.

6.2 Backup Security

The method of back procedure could include:

1. By Manual File Backup: Export or return files as described in the user menu. The backup target is supported by Asset Owner to back up the virtual machine software "Acronis", which completely saves the system image file, system operating software, configuration file, and account list through legal certificates.
2. By Manual Image Backup: Export or return files as described in the user menu. The backup target is supported by Asset Owner to back up the virtual machine software "Acronis", which completely saves the system image file, system operating software, configuration file, and account list through legal certificates.
3. Automatic Image Backup: follow the instructions of the user menu, and full image backup to a NAS Server automatically.

The following figure describes that the image of windows-based host server is kept locally in the park DMZ for a certain period of time (following Employ's backup policy). A copy of the image is transferred to Employ's central data center for long time retention.

6.2.1 Retention and Frequency

- **Windows based host servers**

Backup project	Backup Solution	RPO Target
Windows system image	Use the Windows Backup and Restore automatic schedule to place backup targets at Acronis locations.	Every 6 Month
Configuration file	Use the Windows Backup and Restore automatic schedule to place backup targets at Acronis locations.	Every 6 Month
Palo Alto Log	Use the Windows Backup and Restore automatic schedule to place backup targets at Acronis locations.	According to Employer

- **ICS Devices**

Backup project	Backup Solution	RPO Target

Configuration file	The configuration tool needs to be backed up manually to the on-site windows-based file server.	Every 12 Month or configuration is changed.

- **Network Devices**

Backup project	Backup Solution	RPO Target
Configuration file	The configuration tool needs to be backed up manually to the on-site windows-based file server.	Every 12 Month or configuration is changed.

6.3 Restoration

6.3.1 Testing Request

Until the handover, restoration tests must be performed as part of the testing plan of the vendors.

6.3.2 Testing Exercise

Test cases are provided to perform a full backup, and test cases are provided to perform a restore based on that backup and obtain the full functionality of the automated solution.

One of the windows-based host servers will be tested during the SAT or SIT.

6.4 Disaster Scenarios

6.4.1 Windows based host server crash in

The Disaster Scenarios may be activated when one or more of the following criteria are met:

- The type of outage indicates critical systems will be down at the primary site for more than the RTO hours.
- The Employer determines that critical services cannot be recovered on the primary site.

Restore procedures include:

1. Insert the USB **(Prepare a separate USB drive for each backup and use it exclusively for this purpose and not for other purposes)**
   - Complete the ISO media installed via Rufus
2. Select Recovery boot mode

- Activate BIOS configuration
- BIOS configuration USB boot method

3. Run Acronis Bare Metal Recovery (BMR) after booting
   - Configure asset network address
4. In the network folder
   - Find the path to which it belongs
   - Acronis backup host account and password
   - Find the latest backup data
5. Execute the restore procedure
   - Close Acronis
   - Restart

6.4.2 Malware detected during backup

If a virus (e.g. Ransomware attack on scs environment) is found during backup, remediation efforts could be performed to fix the source of the problem. Knowing what caused the incident directs what actions to take to prevent it from spreading or from happening again:

1. Check to close unauthorized access paths;
2. Remove any malware; and
3. Work with the asset owner (or the Employer), data owner, and production supervisor.

6.4.3 Corrupt configuration file

A corrupt configuration file could follow the instruction of the restore procedure of the user menu to test the recovery from files in a NAS (Local area backup server, to store non-windows OS related files) or portable devices for each backup target. An easy way to restore files out of an image is to use Mount Image from the console. After opening an archive, it is possible to mount any existing volume. The mounted images are available in windows explorer and can be accessed the same way as a physical Hard Disk (HD) (read, write, delete...).

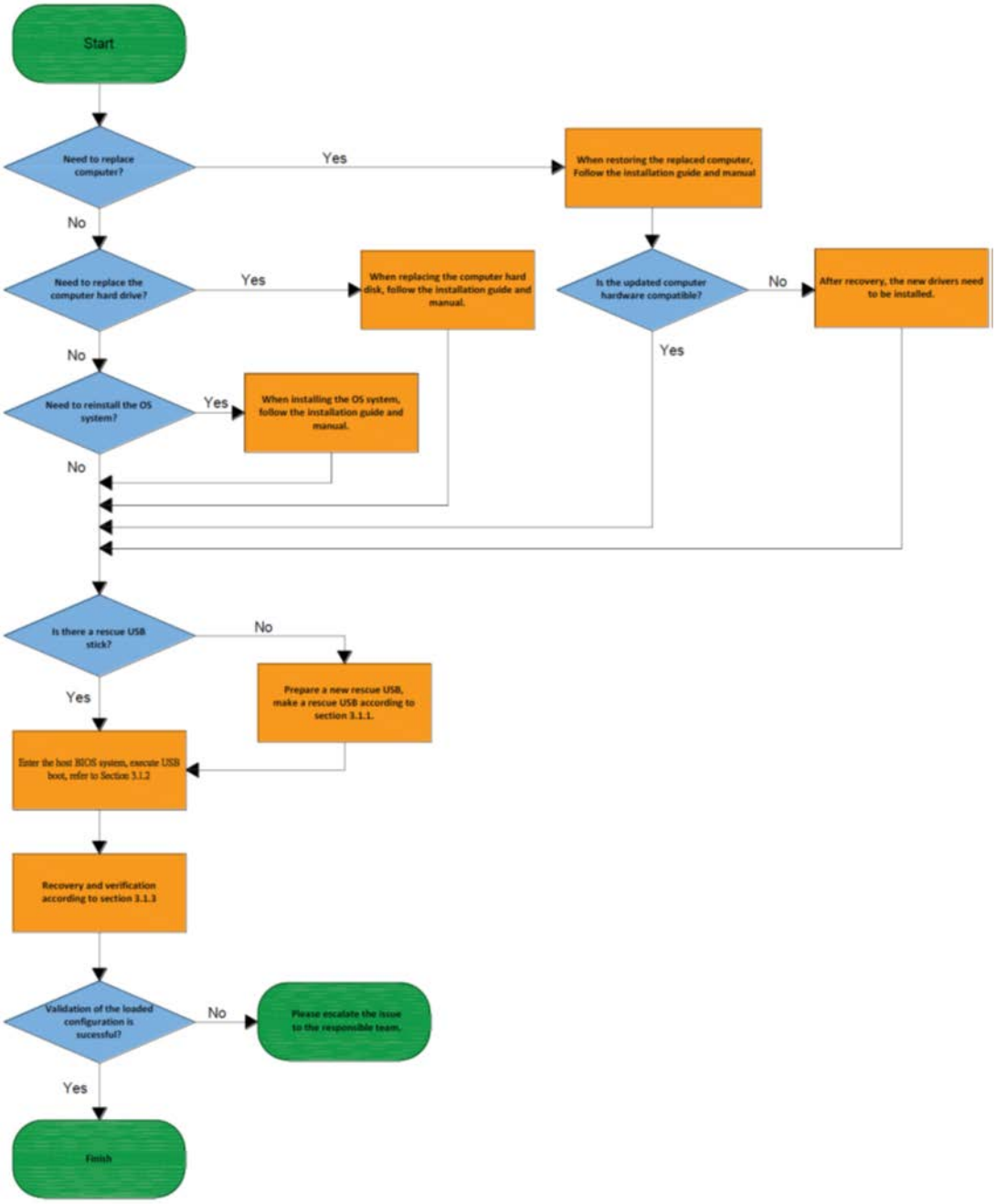
The used portable devices for each backup target are required to **use it exclusively for this purpose and not for other purposes.**

6.5 Recovery Procedures

The recovery plan shall be involved in hardware replacement, software installation, etc.

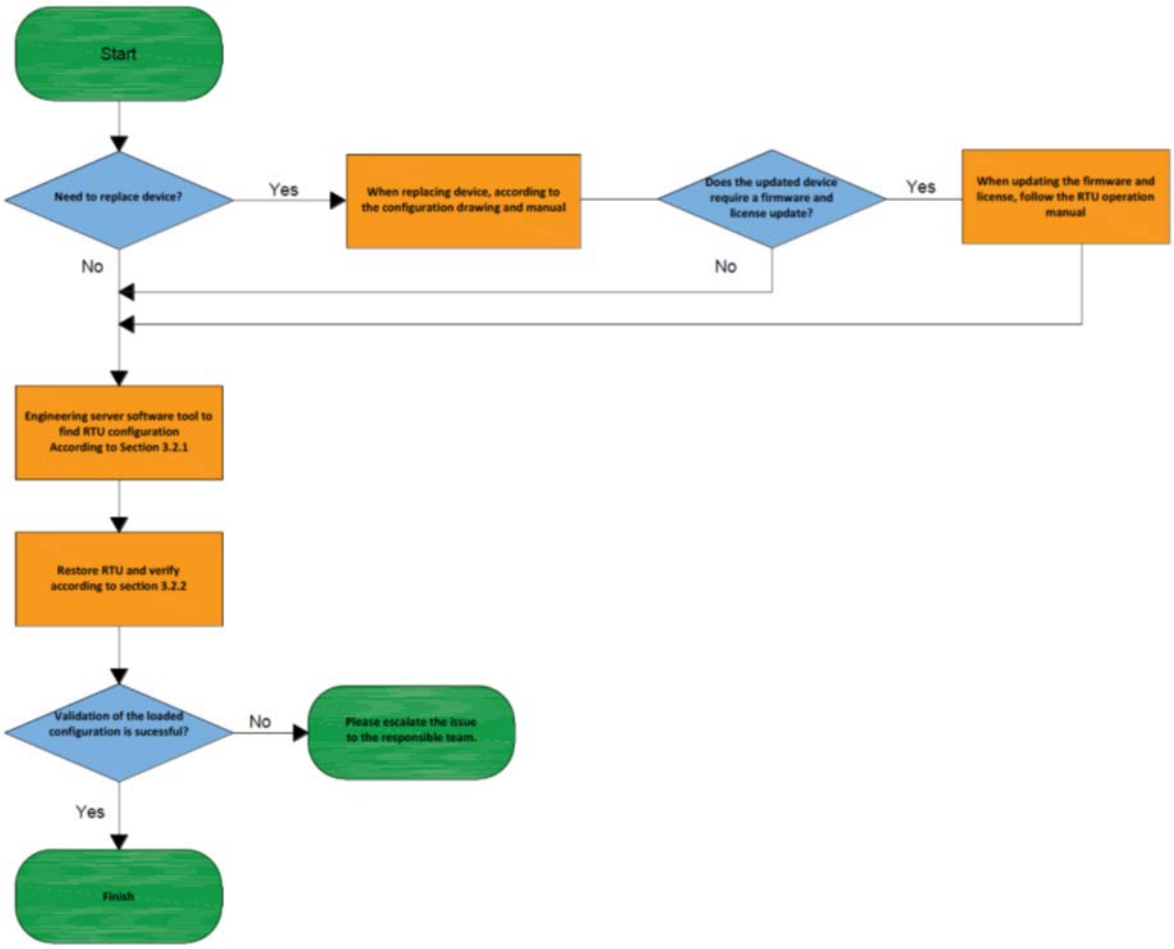
6.5.1 Windows-based host servers Recovery

The following flowchart of recovery procedure is valid for Windows-based host servers. Escalation to the team responsible is necessary if the restoration can’t be completed.


Start
Need to replace computer?
Yes
When restoring the replaced computer, Follow the installation guide and manual
No
Need to replace the computer hard drive?
Yes
When replacing the computer hard disk, follow the installation guide and manual.
Is the updated computer hardware compatible?
No
After recovery, the new drivers need to be installed.
Yes
No
Need to reinstall the OS system?
Yes
When installing the OS system, follow the installation guide and manual.
No
Is there a rescue USB stick?
No
Prepare a new rescue USB, make a rescue USB according to section 3.1.1.
Yes
Enter the host BIOS system, execute USB boot, refer to Section 3.1.2
Recovery and verification according to section 3.1.3
Validation of the loaded configuration is sucessful?
No
Please escalate the issue to the responsible team.
Yes
Finish

6.5.2 ICS and Network Devices Recovery

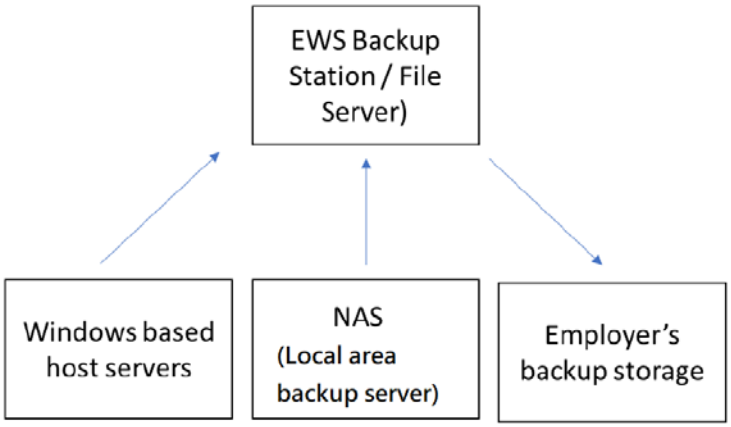
The following flowchart of recovery procedure is valid for ICS Devices and Network Devices. Escalation to the team responsible is necessary if the restoration can't be completed. Below is an example of the recovery process for RTU devices, for all ICS and Network assets in SuC, it should develop their recovery procedures before the end of the FAT stage.



6.6 Logical setup of the backup infrastructure

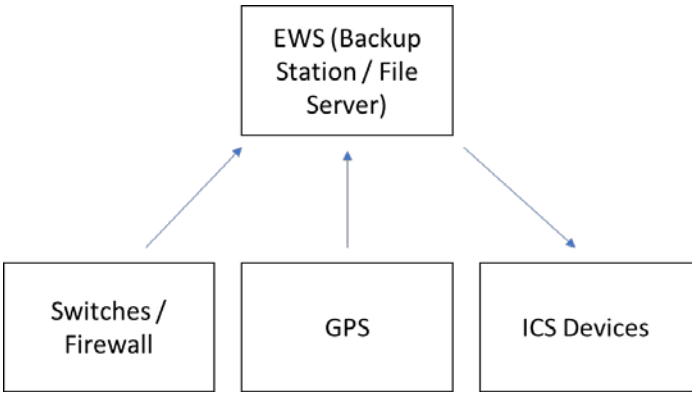
6.6.1 Windows based host server's backup infrastructure

The figure below presents the backup infrastructure for Windows based host servers.



6.6.2 ICS Devices and Network Devices backup infrastructure

The figure below presents the backup infrastructure for ICS Devices and Network Devices.



7.0 Systems Malware Protection procedure

7.1 General Rules

The general rules for malware protection systems are as follows:

1. For the SAT, the on-site host computers (including Windows, MacOS, and Linux OS) should install the antivirus Cortex XDR software package to provide System Malware Protection.
2. After the SAT, if any computer (including Windows, MacOS, and Linux OS) that would be temporarily connected to the on-site network or devices, it should be scanned by the latest version of the anti-virus scanning tool and include in the permit-to-work approval tasks.
3. After the SAT, if any portable media (e.g. USB Drive) would be used to connect to the on-site devices, it must be scanned by the latest version of the anti-virus scanning tool and included in the permit-to-work approval tasks.

7.2 Central Management

7.2.1 Malware Protection for on-site host computers

The requirements of malware protection for on-site host computers are described as follows:

1. An antivirus Cortex XDR (Palo Alto Antivirus) software package should be installed on the host computers, the operation is controlled by the central Palo Alto server.
2. The Palo Alto Antivirus agent is a simple piece of software that runs as a service on the servers' Windows O.S. The agent will recognize file patterns or suspicious software behavior in real time. In such cases the agent will prevent the malware from running and will send alerts to the Palo Alto control center from where the alert will be forwarded to the central SIEM CDC.
3. The centralized Palo Alto control center ensures that virus signatures are downloaded on a daily basis and that application updates are distributed on a regular basis.
4. All Windows, MacOS, and Linux OS host computers that can be protected by Malware Protection in SuC should be install antivirus Cortex XDR (Palo Alto Antivirus) software package and sync to Employer's Malware Protection mechanism. The information on the host computers list for Malware Protection will be provided in Asset List after DTRA.
5. Maintain and update malware protection mechanisms with Employer to update virus patterns and ensure automated solutions perform properly, should be tested in cooperation with Employer's IT.

7.2.2 Malware Protection for computers that temporarily connected to the on-site network or devices

The requirements of malware protection for computers that are temporarily connected to the on-site network or devices are described in the table below.

Requirement	Description
Management of the solution	To scan your host devices for vulnerabilities within installed software, IoT controllers, and firmware updates. • A malware scanner server would be installed on-site and update virus patterns through Employer's approved network connection in DMZ zone area. • Plug a malware scanner for host equipment into a USB port, the equipment can be booted safely from its own operating system. • No software installation needed.
Configuration change	• The Virus patterns were through Employer's approved network connection.
Detection event	• Local Threat Intelligence: enriches all analysis Indicators of Compromise (IOCs) across the security ecosystem and leverages on-premises or private cloud indicator repositories compatible with the Malware Information Sharing Platform (MISP).
Antivrius scan	• High efficacy Mult scanning technology which simultaneously leverages the signatures, heuristics, and machine learning of more than 30 anti-malware engines offering the highest malware detection rates. • Work seamlessly across Windows, MacOS, and Linux, even encrypted drives

7.2.3 Malware Protection for portable medias

The usage of portable media should follow:

- Portable media should be restricted its use to authorized uses.
- Automated mechanisms that recognize portable media and allow its use only if free of known malware.

The requirements of malware protection for portable media are described in the table below.

Requirement	Description
Management of the solution	To act as a digital security guard - inspecting all media for malware, vulnerabilities, and sensitive data of external data sources in portable media. • A malware scanner for end-device equipment with multi-USB interface ports would be installed on-site and update virus patterns through Employer's approved network connection in DMZ zone area. • Insert the media device into malware scanner for host equipment. • Malware scanners for end-device equipment works as a media scanning station to check all files from the device. • A detailed report will be generated after the scan is completed.
Configuration change	• The Virus patterns were through Employer's approved network connection.
Detection event	• Proactively detects 99%+ of malware threats. • Clean & Reconstruct Suspicious files • Detailed report will be generated after the scan is completed.
Antivrius scan	• High efficacy Mult scanning technology which simultaneously leverages the signatures, heuristics, and machine learning of more than 30 anti-malware engines offering the highest malware detection rates.

7.3 UPDATE & PATCH

7.3.1 Logical structure of Malware Protection for on-site host computers

The location of Anti Malware Protection's updates, patches and the method to updates would refer to chap 7.6 Logical structure of Malware protection. The requirements of update and patch for on-site host computers are described in the table below.

Requirement	Description
Whitelisting update	Employer IT will control Whitelisting update.
Signature update	Employer IT will release signature updates on a daily basis.
Patch Management	Employer IT will control software updates.

7.3.2 Logical structure of Malware Protection for computers that temporarily connected to the on-site network or devices.

The location of Anti Malware Protection's updates, patches and the method to updates would refer to chap 7.6 Logical structure of Malware protection. The contractors will provide a standalone device with the patch mechanism for a malware scanner for host equipment update. The requirements of update and patch for computers that are temporarily connected to the on-site network or devices are described in the below table.

Requirement	Description
Signature update	Contractor will release signature updates on a daily basis.
Patch Management	Contractor will control software updates.

7.3.3 Logical structure of Malware Protection for portable medias

The location of Anti Malware Protection's updates, patches and the method to updates would refer to chap 7.6 Logical structure of Malware protection. The requirements of update and patch for portable media are described in the below table.

Requirement	Description
Signature update	Contractor will release signature updates on a daily basis.
Patch Management	Contractor will control software updates.

7.4 Incident Management

The requirements of incident management are described in the table below.

Requirement	Description
Supicious activities	The agent will recognize file patterns or suspicious software behavior in real time. In such cases the agent will prevent the malware from running and will send alerts to the Palo Alto control center from where the alert will be forwarded to the central SIEM CDC. Chap 7.6 describes the connection structure of the agent in windows-based hosts, Palo Alto control center, and Asset Owner’s central SIEM CDC. The agent will report the event log to Palo Alto control center when event occurs, then Palo Alto control center will transfer the event alert to Asset Owner’s central SIEM CDC server and continuously monitoring by Asset Owner’s CDC team.
Malicious activities on server and industrial system	The Palo Alto antivirus service provides protection against viruses, ransom ware or other kinds of malware that possibly could haunt a Windows based installation. The alert will be forwarded to the central SIEM CDC.

7.5 Device with no protection mechanisms

When anti-virus scans and/or firewalls cannot be installed for protection, an intrusion detection solution (e.g. Employer's IDS solution) will be used to analyze the packet traffic, detect abnormal traffic, new IP appear, new assets appear, and new service protocols occurred, to monitor for possible malware activity. The protection scope would include IP-based devices, e.g. RTUs/iRTUs, Servers, Embedded devices (controller, intrusion module, GPS). The logical structure of intrusion detection solution (e.g. Employer's IDS solution) would refer to Chap 8. Logical structure of malicious behavior protection for non-windows-based devices.

7.6 Logical structure of Malware protection

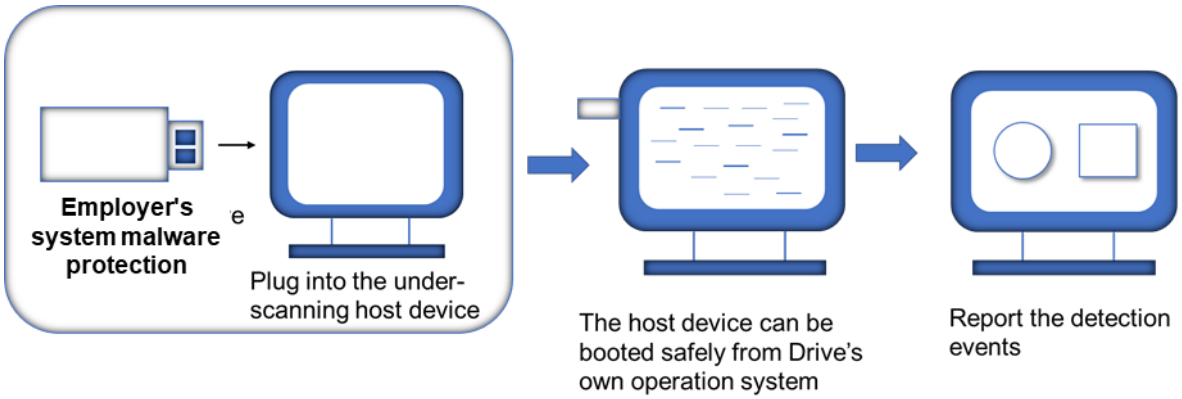
7.6.1 Logical structure of Malware Protection for on-site host computers

- **Logical structure of Malware Protection for on-site host computers**

The below figure is a logical structure example of malware protection for on-site host computers.

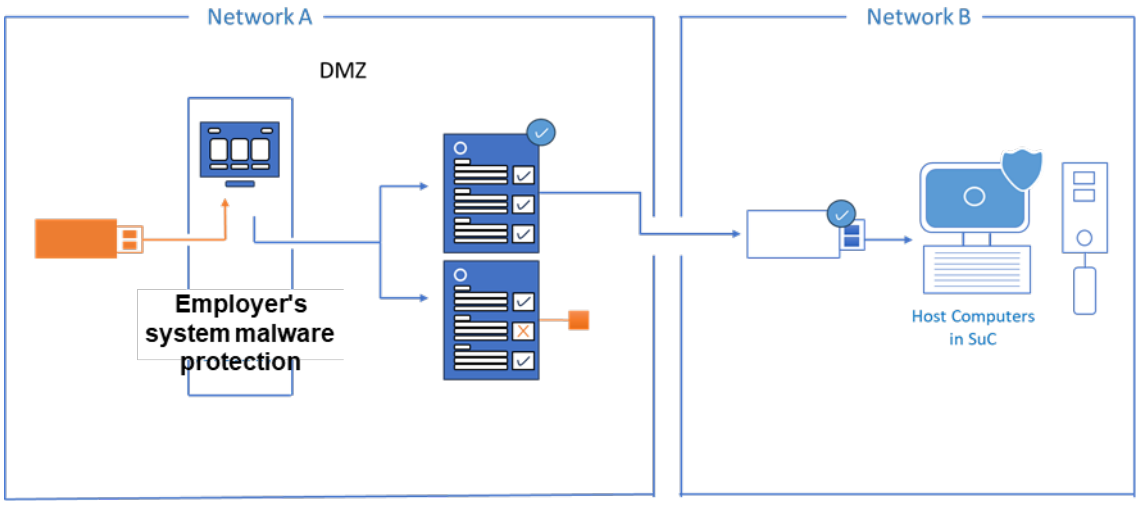
- **Logical structure of Malware Protection for computers that temporarily connected to the on-site network or devices**

The below figure is a logical structure example of malware protection for computers that temporarily connected to the on-site network or devices.



- **Logical structure of Malware Protection for portable medias**

The below figure is a logical structure example of malware protection for portable medias.



8.0 Change and Patch Management procedure

8.1 Main Principles of Configuration

Requirement	Description
Identification	Register as an Asset ID in Inventory Asset List.
Versioning	The versioning of the industrial systems' configuration file shall keep in Inventory Asset List.
CMDB	Refer to the Inventory Asset List to maintain.
Storage	The Inventory Asset List would be approved and managed by the Employer's document system. The configuration files would be stored in the Employer's Backup Station and/or the Employer's Cohesity Backup Repository.
Modification/Change	1. The goal of Modification/Change is to: - Follow the process and pre-requirements of managing and handling patches - On a scheduled basis, patch the Employer's system - Send feedback through reporting to the Employer - Collect test results from the process and the activities and send them to the Employer 2. Once the configuration of the firewalls and network devices have been changed, the new version of the configuration files should be copied to an on-site windows-based file server immediately with a different file name, then the windows-based file server will be regularly backed up to Employer's servers.
Monitoring and Integrity	Following the Employer's process could ensure that changes proposed are reviewed, authorized, tested, implemented, and released in a controlled manner and that the status of each proposed change is monitored.
Alerting	It would use software to compare the configured files to check if there is any change, then review and update the configured files.
Auditing and control	The audit could include: - That risk assessment has been conducted - That plans for rollback exist and are documented - That approvals have been gathered and documented - That the changes are classified according to the requirements in the MoC process The result of the audit is documented and saved as a control record.

Patch Management covers all areas of patching in the system, including but not limited to

- System patching
- Software patching
- Firmware updates

In relation to

- Hardware
- Virtual Environment
- Operating System
- Control, Monitor, and Regulating Software (Primary software component)
- Management Software
- Third-party software in scope of Contractor delivery

All the patching files for each individual asset will copy to a NAS or a Local area backup server, which would be decided during the detailed risk assessment task and a patch management excel file would be built in the NAS to trace all the asset patch version history.

In general, all updates which eventually will strengthen the Confidentiality, Integrity and Availability of the Asset.

8.2 Windows based host servers (WBHS)

8.2.1 WBHS Configuration Files (tentative)

The management of WBHS Configuration Files would use following table for each WBHS asset in SuC. The WBHS asset in SuC list will be defined after detail design and before FAT stage. These would be recorded in a Security Patching section of SuC's Functional Description Specification.

Changes: The modification can be done for individual Windows based host servers in the project. Modification Windows based host servers need to be loaded one by one.

Validation: In Project Configuration Management (PCM) use software to compare the configure files.

Assets in SuC	FAT		SAT	
SCADA HMI Server	Windows system		Windows system	
	Palo Alto		Palo Alto	
	Acronis agent		Acronis agent	
	Splunk agent		Splunk agent	

8.2.2 WBHS Configuration Revision Control & Management Table (tentative)

ITEM No.	(1). Device Name-ID	(2). Manufacturer Name	(3). Manufacturer Model #	(4). Real Time Operating System (OS)	(5). Bios/Firmware	(6). OS/Firmware version	(7). Security software installed (type and version)	(8). inventory data on all network assets are gathered and consolidated
1		SCADA HMI Server						

8.3 ICS & Network Devices Configuration

8.3.1 ICS & Network Devices Configuration Files (tentative)

Changes: The modification can be done for individual ICS & Network Devices in the project. Modification ICS & Network Devices need to be loaded one by one.

Validation: In PCM use software to compare the configure files.

	FAT		SAT	
IED (Control)	Model type		Relay type	
	Firmware		firmware	
	Serial Number		Serial Number	
	Config File		Config File	
IED (Protection)	Model type		Relay type	
	Firmware		firmware	
	Serial Number		Serial Number	
	Config File		Config File	
Ethernet Switch (Control)	Connectivity package version		Connectivity package version	
	Relay Config File		Relay Config File	
	Config Software & Version		Config Software & Version	
Ethernet Switch (Protection)	Connectivity package version		Connectivity package version	
	Relay Config File		Relay Config File	
	Config Software & Version		Config Software & Version	
Wireless AP	Connectivity package version		Connectivity package version	
	Relay Config File		Relay Config File	
	Config Software & Version		Config Software & Version	

8.3.2 ICS & Network Devices Configuration Revision Control & Management Table (tentative)

ITEM No.	(1). Device Name-ID	(2). Manufacturer Name	(3). Manufacturer Model #	(4). Real Time Operating System (OS)	(5). Bios/Firmware	(6). OS/Firmware version	(7). Security software installed (type and version)	(8). inventory data on all network assets are gathered and consolidated

8.4 Change Management

All requested changes related to IT/OT systems of the Dummy project shall follow the same unified and structured process to establish whether it is possible to proceed to implementation of the requested change.

The process should ensure that proposed changes are thoroughly reviewed, authorized, tested, implemented, and released in a controlled manner, while the status of each change is continuously monitored. To meet these requirements, the following principles should be followed:

1. All changes shall be authorized, documented and controlled, which follow the Asset Owner's management of change (Change management) process;
2. Change approval recommendations must be based on a risk assessment, with special consideration given to the impact of the proposed change on system availability;
3. Where feasible, automated tools should be used to provide a real-time, comprehensive overview of all activities associated with change management;
4. Before the change is conducted in the operational environment, the change test should be conducted;
5. Before the change is conducted in the operational environment, the current configuration and data of the related system/device should be backup;
6. Before the change is conducted in the operational environment, the change plan should be document and includes the rollback procedure, which would be conducted while the change fails;
7. Before the change is conducted in the operational environment, it shall be approved by the Asset Owner. Vendor or Maintainer could change notification document to obtain Asset Owner's approval.
8. Risk mitigations should be documented.

If the change is related to legacy systems and is appropriate, it should be handled separately and ensure information security.

Change management process shall include:

- Testing against known criteria prior to deployment to operational environments. All test activities shall be documented according to requirements in Change management.
- Installing patches and making necessary changes to system configuration in accordance with hardware or software vendor guidance. All applications shall be rebooted prior to application of patches.
- Communication/notification of stakeholders, that may be impacted by the patch installation or potential defects arising from the patching.
- Recording patches that have been applied (e.g. in a specialized patch management tool or a Configuration Management Database (CMDB)).
- Regular reporting of the patch level of relevant OT systems.

Patch deployment procedures shall be able to deal with the failed deployment of a patch either with an instant redeployment or rollback procedure of an installed patch. 'Hybrid patching' shall be avoided to ensure rollback is secure.

Patch deployment shall not be performed without a confirmed back-up of the system(s) in scope of the intended deployment.

All patches shall be approved as per the process in Change management prior to deployment.

The urgent changes, which means that they should be implemented as soon as possible, should be categorized with the highest priority when handling the request.

The change of audit should include, but not limited to, the followings:

1. That risk assessment has been conducted;
2. That plans for roll back exists and are documented;
3. That approvals have been gathered and documented;
4. That the changes are classified according to the requirements in management of change (Change management) process;
5. The result of the audit is documented and saved as a control record.

The result of the audit is documented and saved as a control record.

The content of change notification template includes:

- Details of the Change:
  - What is changing? [Provide a brief description of the change, e.g., restructuring, leadership changes, new department, merger, etc.]
  - Why is this change being made? [Explain the rationale behind the decision and its expected benefits, e.g., "to streamline operations," "enhance customer experience," or "align with strategic goals."]
  - Impact on Stakeholders: [Describe how this change will affect the recipient. Be clear and transparent about any actions they need to take, timelines, or new points of contact.]
- Key Dates and Next Steps
  - [Date 1: Description of milestone or event related to the change]
  - [Date 2: Description of another key milestone, if applicable]

8.5 Patch Management

A patch list should be made available by ICP to the PE/O, through an interface commonly accepted by the industrial and security communities, including that identifies:

1. approved security patches applicable to Automation Solution software for which the Project is responsible,
2. which of the applicable security patches have been approved for use in the Automation Solution,
3. the version numbers of the software to which the approved patches apply.

This list shall be available to the PE/O within an agreed timeframe after the release of a patch by the manufacturer. While this patch list is approved and available, ICP and/or vendor of each system could download the patching files and store to NAS before handover. After handover, maintainer should follow the same policy.

All the patching files for each individual asset will save to NAS and a patch management file would be built in the NAS to trace all the asset patch version history. The table of patch management should include following information:

1. Device Name-ID
2. Manufacturer Name
3. Manufacturer Model #
4. Real Time Operating System (OS)
5. Bios/Firmware
6. OS/Firmware version
7. Security software installed (type and version)
8. Inventory data on all network assets are gathered and consolidated
9. Aware of the intent and impact of the change/s
10. Patch status
11. Identify vulnerabilities
12. Deploy the patch to the test group
13. Monitor and record the patch status on the test group
14. Review the impact of the patch and be aware of the downtime and alerts
15. Prepare mitigation for any issues during or after patch deployment to operations
16. Deploy the patch
17. Monitor and record the patch status on operations
18. Issues encountered?
19. Notes

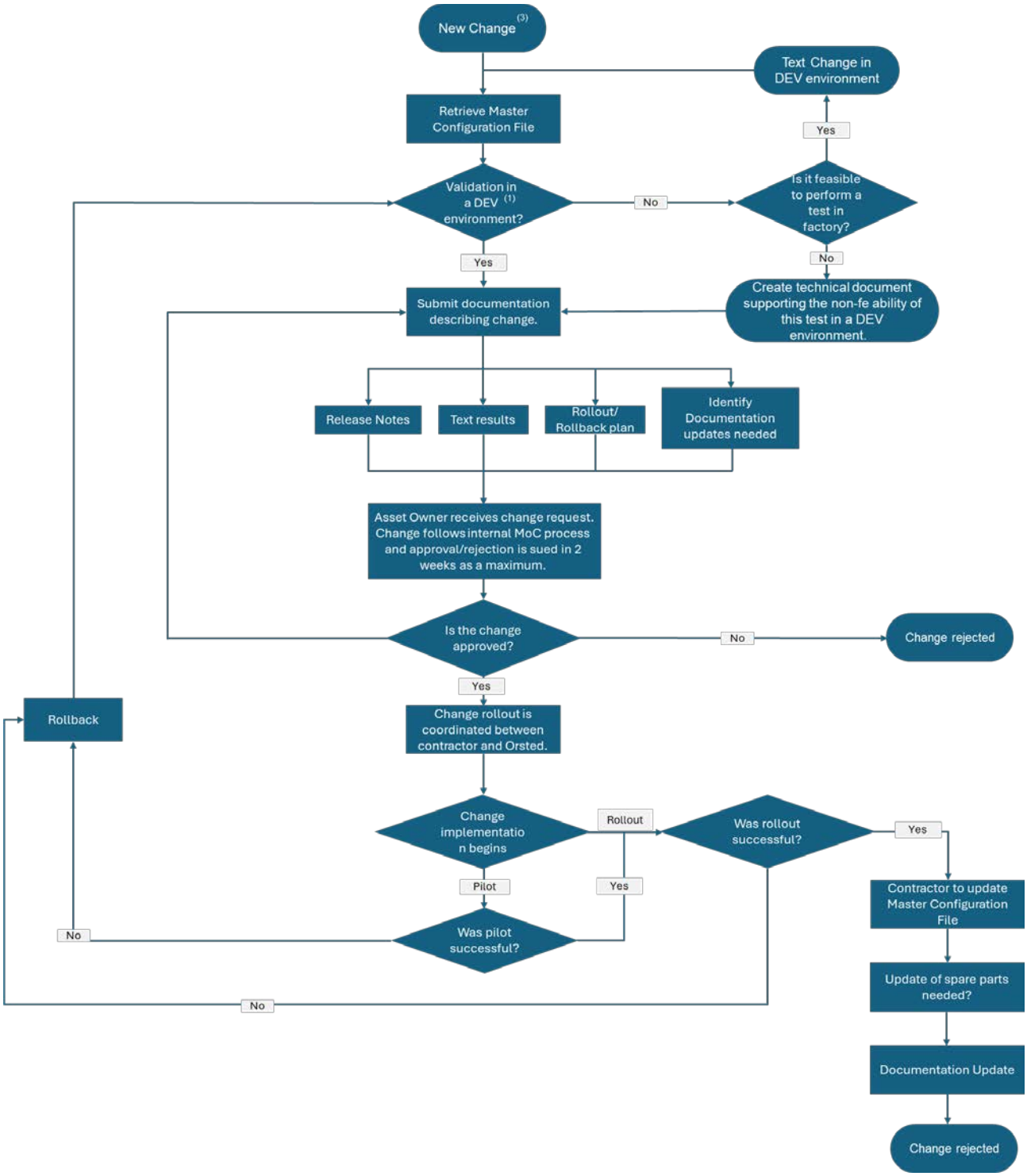
For embedded device asset (RTU and other ICS devices), subcontractor of each SuC asset should save an up-to-date version of patch file to the NAS or local area backup server. The procedures and validation test of patch would be described in a Patching Management section of SuC’s Functional Description Specification (part of Policies and Procedures (PP) document). The patch for embedded device asset should be performed by subcontractor or vendor.

8.5.1 Patch Management Map

When technically possible, automatic mechanism/tools shall be employed to maintain an up-to-date and complete picture of all activities related to the change management.

1. The contractor providing recommendations for change approval shall follow a risk assessment. Special consideration shall be given to the effects of the proposed change on system availability.
2. The contractor must perform a risk assessment of all patches to ensure patches are not negative.
3. Impacting availability or integrity of OT services. See under risk assessments.
4. Risk mitigations related to the change, such as rollback measures, shall be documented.
5. The contractor to ensure a new backup has been taken place before the change commences.
6. The contractor provides The Management of Change as a test plan to ensure sign-off that the process has been followed by the change.
7. From the recommendation, risk assessment and evidence of tests, Employer must approve the change before rolling out.
8. Results of the Change should be documented by the Contractor through Reporting.

8.5.2 Patch Management Process



9.0 Logging, monitoring, and reporting procedure

9.1 Information Logging

9.1.1 Overview of information logging policy

Instruction for Security Logging sets the log requirements necessary to ensure detection and accountability for events in Employer IT/OT systems in Employer's offshore wind farms.

9.1.2 Purpose of information logging policy

Provide an overview of logging ensuring detection and accountability for events in Employer's IT/OT systems in Employer's offshore wind farms.

9.1.3 Scope of information logging policy

Windows based host servers (WBHS) in SuC. Logging shall be performed on WBHS with control functionality or direct network connections to mechanical or energized plant devices.

9.1.4 Information logging policy standard

System Characteristic	Log Content	Log Collection Timeframe
Central client-server type applications Logging shall be performed on central applications with control functionality or direct network connections to mechanical or energized plant devices.	General • System ID and device recognition where possible. • IDs of Users • Dates, times and key events details, such as log-on and log-off. Operational events (i.e. defect on software or hardware) • Software exceptions • System utilization (available disk space, CPU load, memory). Security related events: • Attempts to access the system successfully as well as rejected ones • System configuration alterations • Utilization of privileges • Accessed files and type of access	Logs from decentral devices should be collected daily by the central application. Logs shall be forwarded from the central application to central log server every week.

9.1.5 Information logging policy compliance

- The security related logs would sync to Employer's log server with SPLUNK software and Event Management & Reporting.
- All Windows based host servers (WBHS) in SuC should install SPLUNK software and sync to Employer's log serve to collect the security related logs. The Windows based host server’s information will be provided in Inventory Asset List.
- Logs would be protected against unauthorized access and tampering. Specific measures would be designed and implemented to protect against unauthorized log information changes and operational logging problem, including the following:
  - Alterations to the types of messages recorded
  - Editing or removing log files
  - The logfile media storage space is surpassed, which means either that an event is not registered or that the past events have been over-written.
- All systems would be configured and synchronized with the same time and date to ensure good forensics and reporting. A standard reference time would be defined and shall be used for recording any log event in any Employer OT system and must be synchronized with the Employer’s time synchronized server. The synchronized refence time should be based on a global reference time, used in all parks. If this is not possible, one standard time shall be used across all OT systems and devices in a wind farm.
- Following information should be provided in Policies and Procedures Integration Plan (PPIP) for each asset:
  - Configuration on the logs per system
  - Store the logs, retention of the logs per system
  - Setup time server and provide the time synchronization between each asset
  - Ensure the logs include date and timestamp.
  - Specify that
    - How logging mechanism can be changed?
    - Define roles with rights to change logging mechanism, to delete/change logs, and to configure Syslog server
    - Detail where logs are stored and how that location is protected.
    - Retention time for logs

9.2 Asset Monitoring

9.2.1 Overview of asset monitoring policy

Automated monitoring supports updated and valid data / information regarding OT assets and their operations. Changes in OT asset inventory are collected and updated as are logs collected and assessed all supporting a very high degree of data quality which can be a problem in manual processes.

9.2.2 Purpose of asset monitoring policy

Use Asset Management Software (AMS) to collect the changes in OT asset inventory. Collected data can be used across Instructions to support and provide additional data to increase the Business value of reports and work performed in the OT area.

9.2.3 Scope of asset monitoring policy

All OT assets in scope of this SuC would be monitored and data collected as per the requirements stated. This is to secure updated and valid data that reflects the actuals and contain the needed data per assets for the risks to be handled and assessed.

9.2.4 Asset monitoring policy standard

The monitoring would be performed less than one hour apart for SuC assets.

Asset Management Software (AMS) to monitor assets' status and threats:

- Full visibility into SuC’s OT assets and networks by continuously discovering assets, monitoring for threats, vulnerabilities, supply chain violations and non-compliance issues
- Protects OT/ ICS environments through asset discovery and inventory, network visibility, anomaly / threat detection, vulnerability management, and security compliance.
- Helps OT/ICS organizations defend against sophisticated cyberthreats and stay compliant with internal and industry security compliance requirement. standards.
- Manage risks to OT Assets
- Assets inventory and monitoring
- Zero-trust Network for anomaly detection, network intrusion and malware prevention with Neural Network
- Prevent insider threats, human mistakes
- Meeting Compliance mandates
- Built in supply chain protection, vulnerability assessment
- Help maintain proper network architecture & segmentation

9.2.5 Asset monitoring policy compliance

- Rapidly Discover Devices and Build Asset Inventory
- Immediately Explore Connectivity and Visualize Network Map
- Continuously Monitor Network to Detect and Alert on Threats and Anomalies
- Constantly & Objectively Address OT Vulnerabilities and Risks
- Structured and Streamlined Risk Alert Workflow
- Global, regional & Industry Regulatory Compliance Reporting

- The security related logs would sync to Employer's log server with SPLUNK software and Event Management & Reporting.

9.3 Event Management & Reporting

9.3.1 Security Log Management Goals

The goal of the Event Management is to allow the systems in SuC (described in Scope) to:

- Control resources use and detect anomalies to provide a quality of service.
- Verify that the IS security rules are correctly applied.
- Detect every security failure any anomaly, voluntary or accidental, passive or active, material or human related.
- Detect every law violation or IT/OT equipment abuse.
- Detect the IT/OT equipment uses, against polices or company rules and regulation.
- Be able to give pieces of evidence for forensic investigation or juridical demand.

The deliverable Logging, monitoring, and reporting procedure document for each asset in SuC should include the log file size/storage limitation, type of security events, logging event retention period (log refresh frequency) information, if applicable.

9.3.2 Logging General Setup

All Windows based host servers (WBHS) in SuC would be installed SPLUNK agent to deliver the security logs.

It would transfer copies of logfiles from the Window’s O.S. to Employer’s central SIEM monitoring.

These objectives can be reached by installing a SPLUNK agent on the server’s Windows operating system.

The steps/procedure/screenshots on sending syslogs/logs to SIEM shall be documented in PPIP or any relevant documents and make reference.

9.3.3 Collected Data Quality

It would ensure the data quality, it would use SPLUNK agent to collect the syslog and important information, then send the complete message to the Employer’s central SIEM server.

9.3.4 Data Security and Integrity

The data transport security and integrity of SPLUNK include:

- Transport Layer Security (TLS) inside Splunk – uses industry-standard encryption to protect data in transit across the Splunk infrastructure
- Secure forwarders and deployment servers: Enabling clients to communicate between forwarders and deployment servers and forwarders for enhanced security

9.3.5 Event From the Devices (tentative)

All MS-Windows based hosts/servers will install a SPLUNK agent. The logging frequency would be immediately. The logging retention period in local server is forever, and the logging retention period in central SIEM will depend on Asset Owner's policy. The data transport security and integrity of SPLUNK include:

- Malware Detection event log
- Window Events
  - Login/Logout
  - Unsuccessful Login

9.4 Storing and forwarding of the event

9.4.1 Storing process.

The application logs, security logs, setup logs, and system logs shall be stored in the local windows-based host servers.

9.4.2 Access

The stored application logs, security logs, setup logs, and system logs shall be stored in the local windows-based host servers would be limited to administrator's role could access.

9.4.3 Forwarding

It would transfer copies of logfiles from the Window's O.S. to Employer's central SIEM monitoring system.

9.5 Logical logging Setup

The service serves two security related purposes:

- Detect cyberattacks, and to
- Provide information in case of forensics (after a cyber-attack)

It is necessary to transfer copies of logfiles from the Window's operation system to Asset Owner's central SIEM monitoring. These objectives can be reached by installing a SPLUNK agent on the server's Windows operating system. The principle is sketched in the diagram below.

The SPLUNK agent is capable of:

- Real time transfer of Windows syslog / event log information to the SIEM.
- Monitoring of selected files or folders.

The daemon automatically forwards information from Window's event logs to the SPLUNK Heavy Forwarder in Asset Owner's OT Management Zone. The heavy forwarder will ensure collection and forwarding of the information to Asset Owner's central SIEM monitoring centre.

The SPLUNK agent can be configured to monitor selected files of folders. This could e.g. be relevant information that is picked up from OT devices or applications.

Once the transfer of syslog information is accomplished, the threat detection will be tested to fulfil a set of use cases that will raise proper alarms in the SOC (Security Operations Centre).

The service is enabled by installing a simple agent that runs as a service in the server's Windows operation system.

The agent is configured with the IP address of the SPLUNK Heavy Forwarder. From this point the agent is completely controlled by the Heavy Forwarder.

< TEXT END >